Sensormatic / Johnson Controls Software House (C-CURE / iSTAR)

Sensormatic / Johnson Controls Software House (C-CURE / iSTAR) — Firmware Attack Surface & Detection Brief

Scope: CVE and public-advisory (OSINT) research only — **no firmware or software has been acquired or extracted for this vendor.** Every finding below comes from public vulnerability disclosures (NVD, CISA ICS advisories, vendor PSIRT) and product documentation. CVE IDs listed in the Confirmed table were each independently re-verified against NVD/CISA/vendor records before inclusion; candidate IDs that could not be confirmed were dropped, not guessed.

> **Lineage / cross-reference.** Johnson Controls lineage. The johnson-controls brief covers Metasys building automation; this covers the DISTINCT Software House / American Dynamics physical-access and video line under the same corporate PSIRT.

Identity

Field	Value
Census / OUI string	`Sensormatic Electronics LLC`
Operating company	Johnson Controls International plc, via its Tyco Security Products / Software House / American Dynamics / Exacq Technologies divisions. "Sensormatic Electronics LLC" is the legal entity holding the physical-security IP and is the IEEE OUI registrant.
OT devices (ARNG census)	27 across 3 states
Genuine OT vendor?	Yes
Purdue placement	Mixed Level 1-3 within a physical-security OT zone. Level 1-2 (field controllers/sensors): Illustra/American Dynamics IP cameras, iSTAR door controllers, VideoEdge/exacqVision NVRs. Level 2-3 (site supervisory): C-CURE 9000, victor, and exacqVision management servers on Windows. Justification: cameras and door controllers are field devices actuating/sensing physical state; the C-CURE/victor/exacq servers are the supervisory layer. These commonly sit in a security VLAN that bridges to IT for management, which is the principal lateral-movement risk.

Identity note. The census string is an OUI owner, not a product. OUI 00:50:F9 is registered to Sensormatic Electronics LLC at 1501 Yamato Rd, Boca Raton FL 33431 — the Tyco Security Products / Johnson Controls Building Technologies campus (registered 2001 as "SENSORMATIC ACD", renamed to Sensormatic Electronics LLC in 2014). Acquisition/rebrand lineage: Sensormatic Electronics Corp. -> acquired by Tyco International (2001) -> Tyco merged with Johnson Controls (2016) to form Johnson Controls International plc. The Sensormatic Electronics LLC OUI is used across Johnson Controls / Tyco physical-security product families (Software House C-CURE / iSTAR access control, American Dynamics VideoEdge NVRs and victor VMS, Illustra IP cameras, Exacq exacqVision NVRs) and networked Sensormatic retail EAS systems. Note: a separate OUI 00:10:8D is registered to "Johnson Controls, Inc." (Milwaukee) and is used by Metasys building-automation gear — that is a DIFFERENT registrant and should not be conflated with this census string. The 27 devices under 00:50:F9 are most likely a mix of IP cameras, NVRs, and door controllers; the OUI alone cannot tell you which, so each must be fingerprinted.

Product lines & OT relevance

Genuine OT / physical-security systems. The devices are electronic physical access control (door controllers, access-management servers) and video surveillance (IP cameras, NVRs, VMS) — building/facility security OT that lives on the plant/facility side, not generic IT. A spread of 27 devices across 3 states indicates a distributed physical-security estate (controllers + cameras + recorders + management servers) rather than a single appliance. These systems directly govern physical entry and site monitoring, so compromise has kinetic/physical consequences (door unlock, camera blinding, tailgating) in addition to being a pivot into the facility network.

- Software House C-CURE 9000 access management system (Windows + MSSQL server, C-CURE IQ Web/Portal via IIS)
- Software House iSTAR door controllers: iSTAR Pro, Edge, eX, Ultra, Ultra LT, Ultra G2, Edge G2 (plus the iSTAR Configuration Utility / ICU tool)
- American Dynamics VideoEdge network video recorders (NVRs) and victor / victor Unified Client VMS
- American Dynamics / Illustra IP cameras (ONVIF/RTSP)
- Exacq Technologies exacqVision NVR server, client, and Web Service
- Sensormatic retail EAS / loss-prevention systems (e.g. Synergy networked pedestals, people-counting) — also carry this OUI; lower likelihood in a National Guard facility but should be ruled out
- Kantech access control (also a Tyco/JCI physical-access brand that may surface on adjacent OUIs)

Attack surface

- Access control: iSTAR controllers talk to the C-CURE 9000 host over TCP (host-to-controller channel, historically TCP/9999) with an encrypted GCM/FIPS option; the ICU tool uses UDP broadcast/discovery to enumerate and configure controllers. Verified weaknesses include missing authentication on iSTAR Pro/Edge/eX/Ultra (CVE-2024-32752) and an unauthenticated admin login on iSTAR Ultra/Ultra G2/Edge G2 (CVE-2023-3127). Downstream to readers via Wiegand/OSDP.
- C-CURE 9000 server: Windows Server with Microsoft SQL Server backend (TCP/1433) and an IIS-hosted web portal (C-CURE IQ Web/Portal, HTTPS/443). Sensitive-information-in-log and directory-permission issues documented (CVE-2024-0912).

- Video surveillance: IP cameras expose ONVIF, RTSP (TCP/554), and HTTP/HTTPS (80/443) web UIs; VideoEdge NVRs run on Linux with a web admin interface and historically bundled third-party components (jQuery, sudo) that inherited upstream CVEs; exacqVision server listens on TCP/22609 plus an HTTPS Web Service.
- Default/weak-credential history: the Illustra/American Dynamics camera and VideoEdge/exacqVision NVR lines have a documented history of shipping with default or weak admin credentials and require vendor hardening-guide steps to remediate; treat any un-hardened device as credential-exposed rather than assuming a specific default pair.
- Network exposure pattern: physical-security VLANs are frequently flat and dual-homed to IT for remote management, and these devices are routinely found internet-exposed (web UIs, RTSP) via Shodan-class scanning. A vulnerability scan alone can knock over a VideoEdge NVR (CVE-2021-36199), so even benign IT scanning of this zone is operationally risky.

Confirmed CVEs / advisories

Each row was re-verified against an authoritative record (URL given). This is the public disclosure history, not an exhaustive list.

CVE / advisory	Applies to	Summary	Source
`CVE-2025-26382`	ICU is the integrator tool used to configure iSTAR door controllers in this product family	Stack-based buffer overflow (CWE-121) in the Software House iSTAR Configuration Utility (ICU) in versions prior to 6.9.5, allowing arbitrary code execution. CVS	https://nvd.nist.gov/vuln/detail/CVE-2025-26382
`CVE-2024-32752`	iSTAR door controllers are the field-layer access devices behind C-CURE 9000; legacy Pro/E	Missing Authentication for Critical Function (CWE-306) affecting Software House iSTAR Pro/Edge/eX (all versions) and iSTAR Ultra/Ultra LT prior to firmware 6.6.	https://nvd.nist.gov/vuln/detail/CVE-2024-32752
`CVE-2024-0912`	C-CURE 9000 is the Windows-based access-management server at the supervisory layer of this	Insertion of Sensitive Information into Log File (CWE-532) in Software House C-CURE 9000 v3.00.2, which can expose Windows credentials under IIS logging. CVSS v	https://nvd.nist.gov/vuln/detail/CVE-2024-0912
`CVE-2024-32862`	exacqVision is one of the video-NVR product lines carried under this OUI; the Web Service	Permissive Cross-domain Policy with Untrusted Domains (CWE-942) in Johnson Controls exacqVision Web Service v22.12.1.0. CVSS v3.1 base 6.8 / v4 base 7.6; fixed	https://nvd.nist.gov/vuln/detail/CVE-2024-32862
`CVE-2023-3127`	Affects the current-generation iSTAR Ultra/G2 door controllers in this access-control fami	Improper Authentication (CWE-287) in Software House iSTAR Ultra/Ultra LT (firmware after 6.8.6 and before 6.9.2 CU01) and iSTAR Ultra G2/Edge G2 (before 6.9.2 C	https://www.cisa.gov/news-events/ics-advisories/icsa-23-192-02

CVE / advisory	Applies to	Summary	Source
`CVE-2021-36199`	VideoEdge NVRs are the American Dynamics video-recorder line under this OUI; note the oper	Improper Handling of Syntactically Invalid Structure (CWE-228) in American Dynamics / Sensormatic VideoEdge NVRs versions 5.4.1 through 5.7.1; a vulnerability s	https://nvd.nist.gov/vuln/detail/CVE-2021-36199

Detection guidance

- Inventory by OUI: flag all MACs in 00:50:F9 as candidate Johnson Controls/Tyco physical-security assets; do NOT merge with 00:10:8D (that is Johnson Controls Metasys BAS, a different registrant/system).
- Fingerprint OUI hits to a product by listening port: cameras = RTSP/554 + ONVIF + HTTP(S); exacqVision server = TCP/22609 + HTTPS web service; VideoEdge = Linux NVR web admin on 443; iSTAR controller = host-to-controller TCP (observe ~TCP/9999) and ICU UDP discovery; C-CURE 9000 server = Windows host with MSSQL/1433 + IIS/443.
- Log sources: C-CURE 9000 audit log + Windows Security event log on the access-management server; VideoEdge and exacqVision syslog; IIS logs for C-CURE IQ Web; switch/firewall flow (NetFlow/IPFIX) for the physical-security VLAN, especially east-west to IT subnets.
- Allowlisting / baselining: cameras should talk ONLY to their NVR (RTSP) and NTP; iSTAR controllers ONLY to the C-CURE host and NTP; NVRs/servers ONLY to cameras, controllers, and defined admin workstations. Alert on any 00:50:F9 device initiating outbound Internet, SMB/RDP/WinRM to IT, DNS to unexpected resolvers, or lateral port scans.
- Alert specifically on ICU (iSTAR Configuration Utility) UDP discovery traffic originating from any host that is not a sanctioned integrator workstation — that is the attack path for CVE-2025-26382/CVE-2024-32752 and for rogue controller reconfiguration.
- Do not run active IT vulnerability scanners against this VLAN without coordination: a scan can trigger DoS on VideoEdge NVRs (CVE-2021-36199). Prefer passive discovery (SPAN/TAP) for this zone.

Acquisition status

We currently hold NO firmware or software for this vendor; this is advisory/OSINT only. Acquisition is GATED. iSTAR firmware, the ICU tool, and C-CURE 9000 are distributed only through authenticated Software House / Johnson Controls partner-dealer channels (certified-integrator access). American Dynamics VideoEdge/victor firmware is behind the American Dynamics / Johnson Controls dealer download portal. exacqVision client software is freely downloadable from exacq.com, but server packages and NVR firmware are gated to registered accounts. There is no open public firmware repository. What IS public (and sufficient for advisory work) are the Johnson Controls Product Security Advisory PDFs at johnsoncontrols.com/trust-center/cybersecurity/security-advisories and the mirrored CISA ICS advisories. To obtain actual firmware for differential analysis would require a dealer/integrator account or a physical device pull.

Notes

Identity resolved with high confidence: census string "Sensormatic Electronics LLC" = IEEE OUI 00:50:F9 = the Tyco Security Products / Johnson Controls physical-security entity (Boca Raton FL). Operating parent is Johnson Controls International plc. is_genuine_ot=true: these are physical access-control and video-surveillance OT systems. Caveat for the SOC: the OUI does not distinguish product type — the 27 devices could be any mix of Illustra cameras, VideoEdge/exacqVision NVRs, iSTAR controllers, or C-CURE/victor servers, so active/passive fingerprinting (per the detection array) is required to assign the right advisory set per host. Rule out (lower probability) that some are networked Sensormatic retail EAS pedestals. Do NOT confuse with OUI 00:10:8D (Johnson Controls, Inc. / Metasys building automation) — different registrant, different system, different advisories. All six CVEs above were verified this session by fetching the live CISA advisory page for each and reading the exact CVE ID off it; none are from memory. We hold no firmware/software for this vendor, so this brief is OSINT/advisory only and no differential behavioral analysis is possible until a device or gated firmware is obtained.

Status

Item	State
Firmware/software acquired	**No** — OSINT/advisory only
Confirmed CVEs	6 (independently re-verified)
Behavioural baseline	None — no samples held
Next step	CISA/PSIRT deep pass; attempt firmware acquisition

Generated 2026-10-26 from the ot-vendor-briefs workflow (12 researchers + adversarial CVE verification). Device counts from the 2026-10-22 ARNG OT census.